เอกสารกำหนดความต้องการและแผนพัฒนาระบบ

QR Authenticity & Activation (Web-based)

เวอร์ชัน 1.2 • วันที่ 23/01/2026 • Stack: Next.js App Router + Express + PostgreSQL • Deployment: Docker (Test)

1) ภาพรวมโครงการ

ระบบนี้เป็นเว็บไซต์ (Single Web App) สำหรับการติดตามและยืนยันความแท้ของสินค้าแบบรายชิ้น (Item-level) ด้วย QR Code ที่เป็น Signed/Encrypted token และ Serial Number 12 หลัก (auto running) เพื่อใช้ในกระบวนการ รับเข้าโกดัง → ส่งออกไปคลินิก (รอผู้จัดการอนุมัติ) → คลินิก/ลูกค้าสแกนตรวจแท้ (Public) → ลูกค้าเปิดใช้งานสินค้า (Activation) ได้ 1 ครั้ง

เป้าหมาย

- ลดความเสี่ยง QR ปลอมหรือเดา token ได้ (ใช้ Signed/Encrypted token)
- ทำให้ทุกชิ้นสินค้ามีตัวตนดิจิทัล (Serial 12 หลัก) เชื่อมกับฐานข้อมูล
- ทำงานผ่านมือถือได้ (สแกนผ่านเว็บ) ทั้ง iPhone/Android
- มี Board ให้ Manager อนุมัติการส่งออกก่อนสถานะออกจากคลัง
- Public scan เห็นผลทันที (ไม่ต้องล็อกอิน) และมี Activation form + Consent ตาม PDPA
- พิมพ์สติกเกอร์ 4x6 (Thermal) 1 ดวง/หน้า: QR + Serial 12 หลัก

ขอบเขตงาน (MVP)

- Authentication (Username/Password) + RBAC (Warehouse/Manager/Admin)
- Master Data: Clinic (ชื่อ + จังหวัด, สาขา optional) และ User management (เพิ่ม/ปิด/รีเซ็ตพาสเวิร์ด)
- Inbound (GRN) + Pairing/สร้าง Serial + ออก QR token
- Outbound request + Manager Approval Board
- Public Verify (TH/EN) + แสดงชื่อคลินิก (จังหวัด/สาขา)
- Activation form (TH/EN): ชื่อ อายุ เพศ จังหวัด (required) + เบอร์โทร (optional) + ยอมรับเงื่อนไข (required) และล็อก 1 ครั้ง
- Reprint QR (ออก token version ใหม่ และ revoke ของเดิม)
- Return (ขั้นต่ำ): รับคืนและเปลี่ยนสถานะ + event log (ยังไม่ทำลบข้อมูล)

นอกขอบเขต (ยังไม่ทำใน MVP)

- Dashboard เชิงลึก/BI แบบเต็มรูปแบบ (ทำได้ภายหลัง)
- Integration กับ ERP/ระบบขนส่ง
- Geolocation verification / anti-copy ขั้นสูง
- Workflow เคลม/ซ่อม/คืนแบบละเอียด (ตอนนี้ทำขั้นต่ำ)

2) ผู้ใช้งานและสิทธิ์ (Roles & Privacy)

Role	สิทธิ์/ขอบเขต
Public	ไม่ต้องล็อกอิน • สแกน Verify/Activate • เห็นข้อมูลจำเป็นเท่านั้น (ไม่แสดงวันส่งออก/อนุมัติ)
Warehouse	ล็อกอิน • สร้าง GRN/รับเข้า/พิมพ์ QR • สร้าง Outbound request • รับคืน • Reprint
Manager	ล็อกอิน • Approval Board: อนุมัติ/ปฏิเสธ Outbound • ดูรายละเอียด
Admin	ล็อกอิน • จัดการ Clinics • จัดการ Users (เพิ่ม/ปิด/รีเซ็ตพาสเวิร์ด) • ตั้งค่า/คีย์ระบบ

Privacy Rule: หน้า/ข้อมูลภายในทั้งหมดต้องผ่าน Login และตรวจ Role ซ้ำที่ Backend (ไม่พึ่ง Frontend อย่างเดียว).

3) User Journey & Flow

Flow 1: รับเข้า → ส่งออก → คลินิกตรวจแท้ → ลูกค้าเปิดใช้งาน

1. Warehouse รับสินค้าเข้าคลัง: เปิดหน้า GRN บนเว็บ → กรอกข้อมูลใบรับสินค้า + ข้อมูลสินค้า (บังคับกรอกทั้งหมดตามแบบฟอร์ม)
2. ระบบสร้าง Serial 12 หลัก (auto running ทั้งบริษัท) ต่อสินค้าแต่ละชิ้น และออก QR token (Signed/Encrypted) ผูกกับ Serial
3. Warehouse พิมพ์สติกเกอร์ 4x6 (1 ชิ้น/หน้า) แล้วแปะบนสินค้า
4. เมื่อส่งออก: Warehouse สร้าง Outbound request (เลือกคลินิก + วิธีส่ง + รายการสินค้า) → สถานะรออนุมัติ
5. Manager เข้าหน้า Board อนุมัติ/ปฏิเสธ → ถ้าอนุมัติ ระบบบันทึกคลินิกปลายทางของสินค้า
6. เมื่อถึงคลินิก: แพทย์/พนักงานคลินิกสแกน QR แบบ Public เพื่อดูว่าสินค้าของแท้ (เห็นผลทันที)
7. ก่อนลูกค้าใช้งาน: ลูกค้าสแกน QR แบบ Public → กด Activate → กรอกฟอร์ม + ยอมรับเงื่อนไข → เปิดใช้งานได้ 1 ครั้งและล็อกถาวร

Flow 2: คืนสินค้า (ขั้นต่ำใน MVP)

8. คลินิกส่งสินค้าคืน → สินค้ากลับถึงคลัง
9. Warehouse สแกน Serial/QR เพื่อรับคืนและเปลี่ยนสถานะเป็น RETURNED
10. ยังไม่ทำการลบข้อมูล (ตามที่ตกลง) แต่ต้องมี event log ว่าเกิดการคืน

Flow 3: QR เสียหาย → Reprint

11. คลินิกส่งสินค้ากลับมาที่คลังเพื่อรีพริ้น หรือ Warehouse รีพริ้นจาก Serial ได้

12. ระบบออก QR token เวอร์ชันใหม่ (token_version +1) และ revoke token เก่า
13. สแกน token เก่าจะขึ้นสถานะว่า QR ถูกเปลี่ยนใหม่แล้ว (Reprinted/Replaced)

4) Functional Requirements (FRD)

4.1 QR Code & Serial

- Serial Number = ตัวเลข 12 หลัก (auto running กลางทั้งบริษัท) เช่น 000000123456
- QR = Signed/Encrypted token (แนะนำ JOSE/JWE) เพื่อกันปลอม/เดา token
- Label แสดง QR + Serial 12 หลัก ใต้ QR
- Token versioning: รองรับ Reprint โดย revoke token เก่า

4.2 Public Verify (TH/EN) — ต้องเห็นผลทันที

- สแกนแล้วแสดงผลทันที (ไม่ต้องล็อกอิน) ผ่านหน้า /verify
- แสดงข้อมูลสินค้า: ชื่อสินค้า, รุ่น/ขนาด/บรรจุ, รหัสสินค้า (SKU), วันหมดอายุ (DD/MM/YY), Serial 12 หลัก
- แสดงปลายทางคลินิก: “ชื่อคลินิก (จังหวัด)” และใส่สาขาได้ถ้ามี เช่น “ABC Clinic (ภูเก็ต)”
- ไม่แสดงข้อมูลภายใน เช่น วันส่งออก/วันอนุมัติ, รายละเอียดผู้ส่ง/พนักงาน

4.3 Activation (TH/EN) — เปิดใช้ได้ 1 ครั้งแล้วล็อกถาวร

- ฟอร์มบังคับกรอก: ชื่อ, อายุ, เพศ, จังหวัด
- ฟอร์มไม่บังคับ: เบอร์โทร
- ต้องติ๊กยอมรับเงื่อนไขการใช้งานและยินยอมให้จัดเก็บข้อมูล (Consent)
- หลัง submit สำเร็จ สินค้าถูกตั้งสถานะ ACTIVATED และห้ามเปิดซ้ำ (ขึ้นข้อความ Activated แล้ว)

4.4 Inbound (GRN) — บังคับกรอกทั้งหมดตามแบบฟอร์ม

ชุดข้อมูลจากไฟล์ Requirement (ใบรับสินค้าเข้าคลัง):

- หมายเหตุ: ฟิลด์ประเภทสินค้า/หมวดหมู่ และหน่วยนับ (Unit) ใช้เป็น Dropdown จาก Master Data (จัดการได้ในหน้า Admin).

ฟิลด์	รายละเอียด/กติกา
เลขที่ใบรับสินค้า (GRN No.)	Auto running (เช่น GRN-2026-000001)
วันที่รับสินค้า	วันเวลารับเข้าคลัง
พนักงานตรวจรับ	ชื่อผู้ตรวจรับสินค้า
สาขา/คลังสินค้า	เลือกจาก master หรือกรอก
PO No.	เลขที่ใบสั่งซื้อ

ชื่อผู้ขาย/บริษัทผู้จัดส่ง	Required
Delivery Note No.	เลขที่เอกสารส่งสินค้า/ใบส่งของ
ที่อยู่ผู้จัดส่ง	รวมเบอร์โทร + ชื่อผู้รับ
วันที่ออกเอกสารส่งสินค้า	Required
Item Code/SKU	Required
Item Name	Required
ประเภทสินค้า/หมวดหมู่	เช่น ฟิลเลอร์/เมโส/สกินแคร์ หรือ เครื่องสำอาง/เครื่องมือแพทย์/ยา
รุ่น/ขนาด/ปริมาณบรรจุ	เช่น 1ml, 2ml, 3ml, 5ml, 10ml, 100 unit ฯลฯ
Quantity Received	จำนวนรับเข้าจริง
Unit	เช่น กล่อง/ขวด/ซอง/เส้น/ชุด ฯลฯ
Lot/Batch	สำหรับติดตามสินค้า
MFG/EXP	รูปแบบ DD/MM/YY และต้องแสดงผลแบบเดียวกัน
สถานะตรวจสินค้า	เช่น ถูกต้องครบถ้วน/เสียหาย/เคลม/แตก/ไม่ครบ ฯลฯ
หมายเหตุ	เช่น กล่องบุบ, จำนวนไม่ตรง ฯลฯ
ผู้อนุมัติ/ผู้จัดการคลัง	Required
วันที่อนุมัติ	Required

4.5 Outbound (Delivery Note) + Manager Approval Board

ชุดข้อมูลจากไฟล์ Requirement (ใบส่งสินค้า):

- หมายเหตุ: ฟิลด์วิธีการส่ง (Shipping Method) ใช้เป็น Dropdown จาก Master Data (จัดการได้ในหน้า Admin).

ฟิลด์	รายละเอียด/กติกา
Delivery Note No.	อ้างอิงเอกสาร
วันที่ส่งสินค้า	วันเวลาส่งออก
ผู้จัดส่ง/ผู้ตรวจออกสินค้า	ชื่อพนักงาน

สาขา/คลังต้นทาง	เลือกจาก master หรือกรอก
วิธีการส่ง	เช่น GRAB / ปณ / Inter express / ผู้แทน
ชื่อพนักงานขาย	เช่น ชื่อผู้แทนขาย
ช่องทางติดต่อกลับบริษัทฯ	ชื่อบริษัท/Line ID/เบอร์โทร/email
ชื่อคลินิก/ลูกค้า	ชื่อบริษัท/ชื่อคลินิก/ชื่อแพทย์
ที่อยู่คลินิก	ที่อยู่/สาขา
เบอร์โทร/อีเมล	ชื่อผู้รับ/เบอร์โทร/อีเมล
PO No.	เลขที่ใบสั่งซื้อ
รายการสินค้า	SKU/ชื่อ/หมวด/รุ่น-ขนาด/lot/exp/จำนวน/unit
สถานะสินค้า	เช่น สภาพปกติ/มีข้อสังเกต
ผู้อนุมัติ/ผู้จัดการคลัง	Manager อนุมัติใน Board
หมายเหตุ	เช่น สินค้าพิเศษ ต้องเก็บอุณหภูมิ

4.6 Admin Module

- Clinic master: ชื่อคลินิก (required), จังหวัด (required), สาขา (optional), active/inactive
- User management: เพิ่มผู้ใช้, กำหนด role, ปิดการใช้งาน, รีเซ็ตพาสเวิร์ด, บังคับเปลี่ยนพาสครั้งถัดไป (แนะนำ)
- Master Data (Dropdown): จัดการรายการประเภทสินค้า/หมวดหมู่ (Product Categories), หน่วยนับ (Units), และวิธีการส่ง (Shipping Methods) เพื่อใช้ในฟอร์ม GRN/Outbound ให้เป็นมาตรฐาน.

ชุดมาตรฐานเริ่มต้น (Default Seed) สำหรับ Dropdown (แก้ไขได้ผ่าน Admin):

- Product Categories: ฟิลเลอร์, เมโส, สกินแคร์, ยา, เครื่องมือแพทย์, เครื่องสำอาง, อื่นๆ
- Units: ชิ้น, กล่อง, ขวด, ซอง, หลอด, เส้น, ชุด, แพ็ก
- Shipping Methods: GRAB, ปณ, Inter express, ผู้แทน, Messenger, รับเองที่คลัง

4.7 PDF Label 4x6 (Thermal) — 1 ชิ้น/หน้า

- ขนาด 4x6 นิ้ว (101.6 x 152.4 mm) 1 หน้า/1 Serial
- เนื้อหา: QR + Serial 12 หลัก เท่านั้น
- มี safe margin 4–6 mm กันโดนตัด
- พิมพ์ด้วยโหมด Actual size / 100% (ห้าม Fit to page)

5) Data Model (Draft)

ตารางหลักที่แนะนำ (PostgreSQL):

ตาราง	ใช้เพื่อ
users	username, password_hash, role, is_active, force_pw_change
clinics	clinic_name, province, branch_name, is_active
product_items	serial12 (unique), sku, name, category, model_size, lot, mfg_date, exp_date, status, assigned_clinic_id
qr_tokens	product_item_id, token_version, token_hash, status(ACTIVE/REVOKED), issued_at, revoked_at, reason
grn_headers + grn_lines	ข้อมูลใบรับสินค้า + line ต่อชิ้นสินค้า
outbound_headers + outbound_lines	ข้อมูลใบส่งสินค้า + line ต่อชิ้นสินค้า + สถานะ request/approved/rejected
activations	product_item_id, name, age, gender, province, phone(optional), consent_at, policy_version
scan_logs	บันทึกการสแกน (token_version, result, scanned_at, ip_hash)
event_logs	audit log: inbound/outbound/approve/reprint/return/activate

ข้อกำหนด Index/Constraint สำคัญ

- product_items.serial12 ต้อง unique และเป็นตัวเลข 12 หลัก
- qr_tokens ต้อง unique ตาม (product_item_id, token_version)
- sequence running เอกสาร (GRN/OUT/Serial) ต้อง atomic กันเลขชน (ใช้ transaction/row lock)

Master Data Tables (Dropdown)

ตาราง Master สำหรับ Dropdown เพื่อบังคับมาตรฐานข้อมูลในการกรอกฟอร์ม:

ตาราง	ตัวอย่างข้อมูล
product_categories	Filler / Meso / Skincare / Medicine / Device / Cosmetic / Other (TH: ฟิลเลอร์ / เมโส / สกินแคร์ / ยา / เครื่องมือแพทย์ /

	เครื่องสำอาง / อื่นๆ)
units	ชิ้น / กล่อง / ขวด / ซอง / หลอด / เส้น / ชุด / แพ็ก
shipping_methods	GRAB / ปณ / Inter express / ผู้แทน / Messenger / รับเองที่คลัง
warehouses (optional)	คลังหลัก / คลังสาขา A / คลังสาขา B (ถ้าต้องการบังคับเลือก)

6) API Spec (ฉบับส่งทีม — โครง Endpoint)

Endpoint	รายละเอียด
POST /api/auth/login	ล็อกอิน (username/password) → ตั้ง httpOnly cookie
POST /api/auth/logout	ออกจากระบบ
GET /api/auth/me	ดึงข้อมูล user + role
GET /api/public/verify?token=...	Public verify (TH/EN) → คืนสถานะ + ข้อมูลแสดงผล
POST /api/public/activate	Public activate (ครั้งเดียว)
POST /api/grn	สร้าง GRN header
POST /api/grn/{id}/lines	เพิ่ม line + สร้าง Serial + สร้าง QR token
GET /api/grn	รายการ GRN
GET /api/grn/{id}	รายละเอียด GRN
POST /api/outbound	สร้าง outbound request
POST /api/outbound/{id}/submit	ส่งขออนุมัติ
GET /api/manager/board	Manager board
POST /api/outbound/{id}/approve	Approve
POST /api/outbound/{id}/reject	Reject
POST /api/warehouse/reprint	Reprint label จาก serial
POST /api/warehouse/return	รับคืนสินค้า (ขั้นต่ำ)

POST /api/warehouse/labels	Export PDF 4x6 (รับ serials[])
CRUD /api/admin/clinics	จัดการคลินิก
CRUD /api/admin/users	จัดการผู้ใช้ + reset password
CRUD /api/admin/masters/product-categories	จัดการ Dropdown ประเภทสินค้า/หมวดหมู่
CRUD /api/admin/masters/units	จัดการ Dropdown หน่วยนับ
CRUD /api/admin/masters/shipping-methods	จัดการ Dropdown วิธีการส่ง

Result Codes (ตัวอย่างที่ใช้ใน Public Verify)

- GENUINE_IN_STOCK / GENUINE_SHIPPED / ACTIVATED / RETURNED
- REPRINTED (token เก่า) / INVALID_TOKEN / NOT_FOUND / REVOKED

7) UI Spec (Next.js App Router) + i18n TH/EN

- ใช้ App Router และกำหนด locale เป็น segment: /th/... และ /en/...
- โครงหน้าแนะนำ: (public) verify/activate, (auth) login, (private) warehouse/manager/admin
- ใช้ middleware ตรวจ cookie แล้วกัน route private + ตรวจ role
- ทุกข้อความบน UI รองรับ TH/EN (รวม error/validation)

8) Docker-first Development Plan (Windows + Docker Desktop)

Repo & Scripts (npm workspaces)

- Root package.json ใช้ npm workspaces: apps/* และ packages/*
- apps/web: Next dev server (3000), apps/api: Express (4000)
- infra/docker-compose.yml: nginx (8080) + web + api + postgres + redis

ทดสอบสแกนบนมือถือ (iPhone/Android)

- เพื่อให้กล้องทำงานเสถียร ให้ใช้ HTTPS ผ่าน tunnel (เช่น ngrok) ชี้พอร์ต 8080
- เพราะโดเมนเดียว /api → cookie auth และไม่มีปัญหา CORS

9) แผนงานพัฒนา (Sprint Plan)

Sprint	Deliverables
Sprint 0 (Setup)	Monorepo + TS + Prisma + Docker compose (nginx/web/api/db/redis) + seed

	admin/roles/clinics
Sprint 1 (Auth/RBAC + Admin)	Login + middleware guard + Admin clinics/users (add/disable/reset) + i18n skeleton TH/EN
Sprint 2 (QR + Public Verify)	QR token (jose) + verify endpoint + scan UI + rate limit + scan log
Sprint 3 (GRN + Outbound + Board)	GRN form (required) + line create (serial+token) + outbound request + manager board approve/reject
Sprint 4 (Activation + PDF 4x6)	Activate once + consent + PDF 4x6 export (1 serial/page) + print guidance
Sprint 5 (Reprint + Return minimal)	Reprint versioning + return status + event/audit logs

10) UAT Checklist (ทดสอบก่อนใช้งาน)

- Login/Role: Warehouse/Manager/Admin เข้าได้ตามสิทธิ์; Public เข้าได้เฉพาะ verify/activate
- GRN: บังคับกรอกครบ + date format DD/MM/YY + EXP > MFG + serial ไม่ซ้ำ
- Outbound: request → manager approve → public verify แสดงคลินิกถูกต้อง
- Activation: ทำครั้งแรกสำเร็จ; ครั้งถัดไปล็อกถาวร
- Reprint: token เก่าแสดง Reprinted; token ใหม่ยัง verify ได้
- หน้า Admin เพิ่มเติม: Master Data สำหรับ Dropdown (Product Categories/Units/Shipping Methods) พร้อมหน้าจัดการเพิ่ม-แก้ไข-ปิดใช้งาน.
- PDF 4x6: ดาวน์โหลดได้ 1 หน้า/1 ดวง และพิมพ์แล้วสแกนได้ (Actual size 100%)

11) Open Items / คำถามเพื่อ finalize (หากต้องการความเป๊ะก่อน Dev ลงมือ)

- PDPA/Terms: ข้อความยินยอมและเวอร์ชัน policy ที่จะใช้จริง (TH/EN) — ใช้แบบจำลองมาตฐานไปก่อน
- รูปแบบ Serial: ใช้เลข 12 หลักล้วน (ปัจจุบันล็อกเป็นเลข 12 หลักล้วน)
- รายการหมวดหมู่สินค้า/หน่วยนับ/วิธีการส่ง: ใช้ Dropdown จาก Master Data และมีชุดมาตรฐานเริ่มต้น (Default Seed) ในระบบ (Admin ปรับได้).
- ต้องการให้ใช้ Public verify อย่างเดียว